



补天白帽黑客城市沙龙南京站

战略合作



合作伙伴



联合宣传

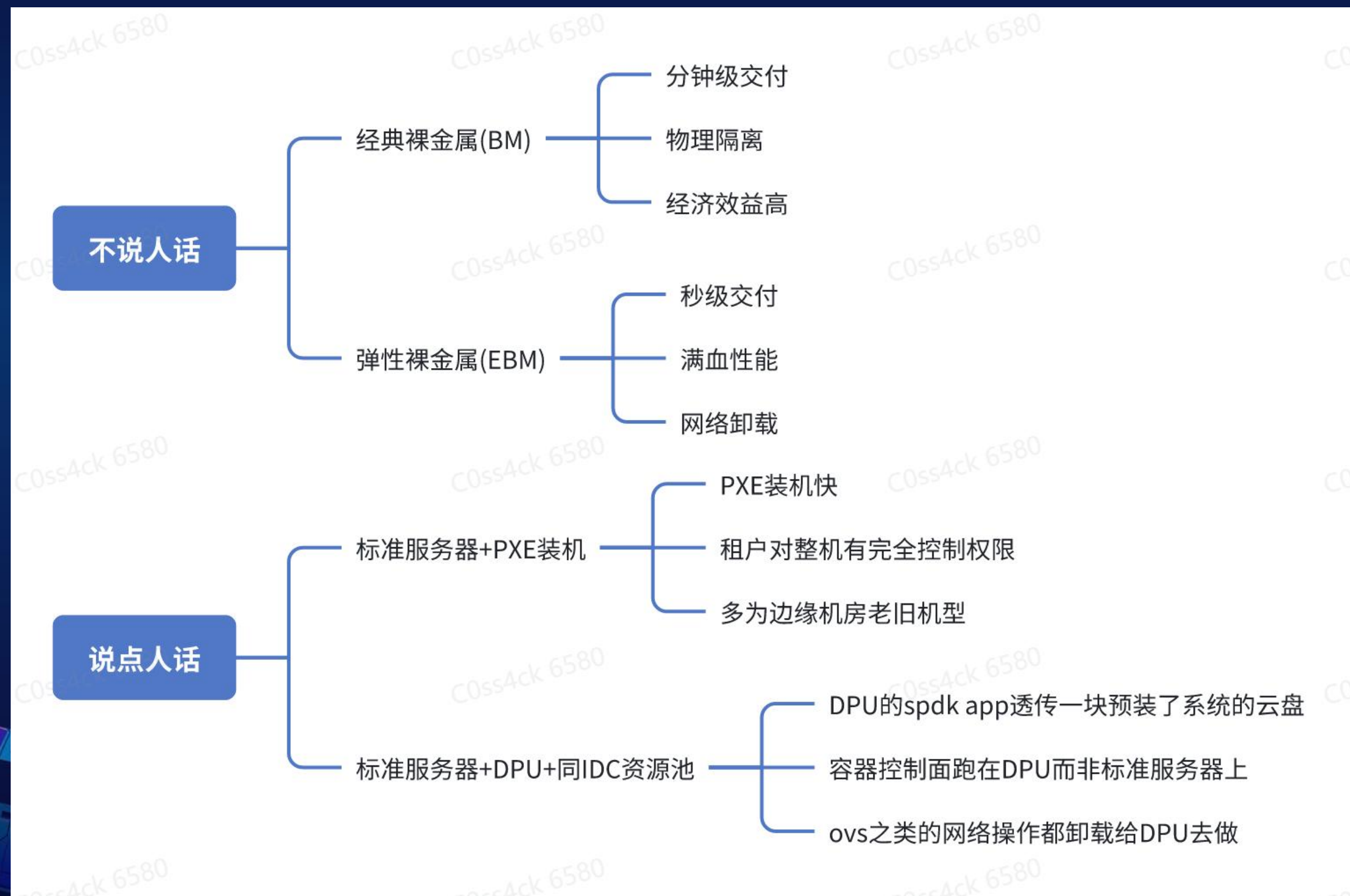


Who touched my Bare Metal

裸金属服务器的固件威胁建模+**BMCWALK**介绍

演讲人：C0ss4ck

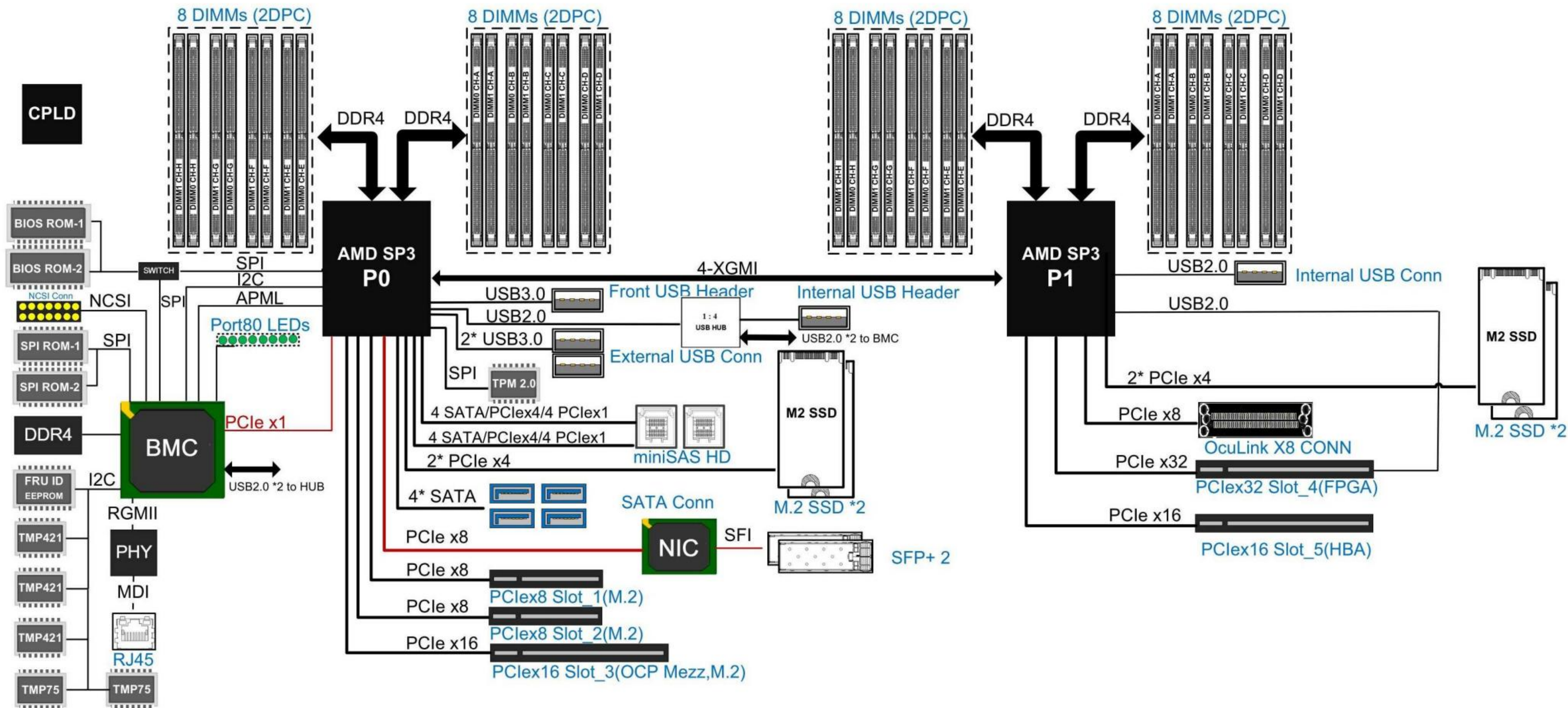
1. 拆解BM



1.1. 标准服务器

以微软开源的Project Olympus的EPYC机型主板的Block Diagram为例，和消费级主板的最大区别是——

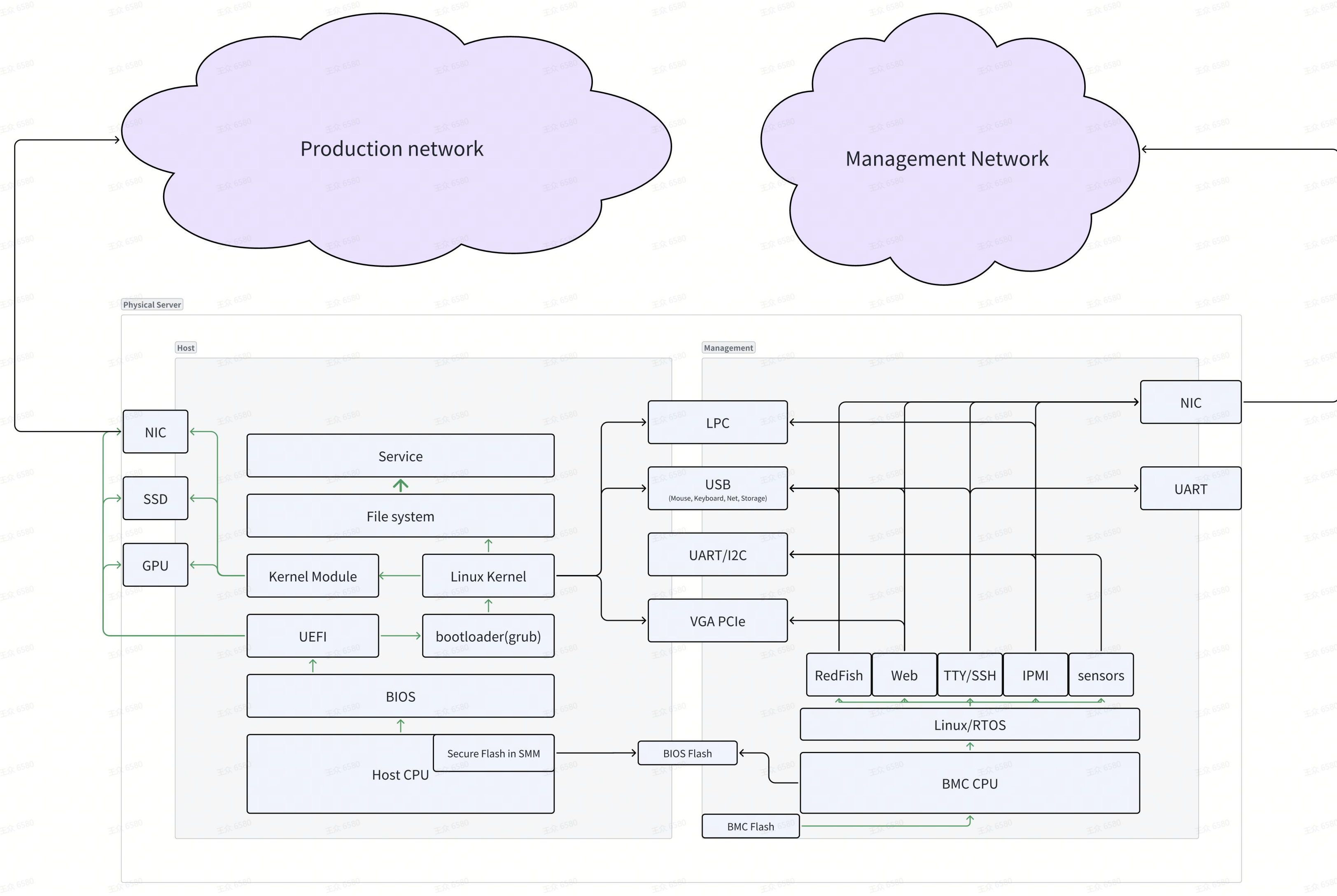
- 服务器U内存通道多
- PCIe特别多
- 带BMC模块



1.1. 标准服务器

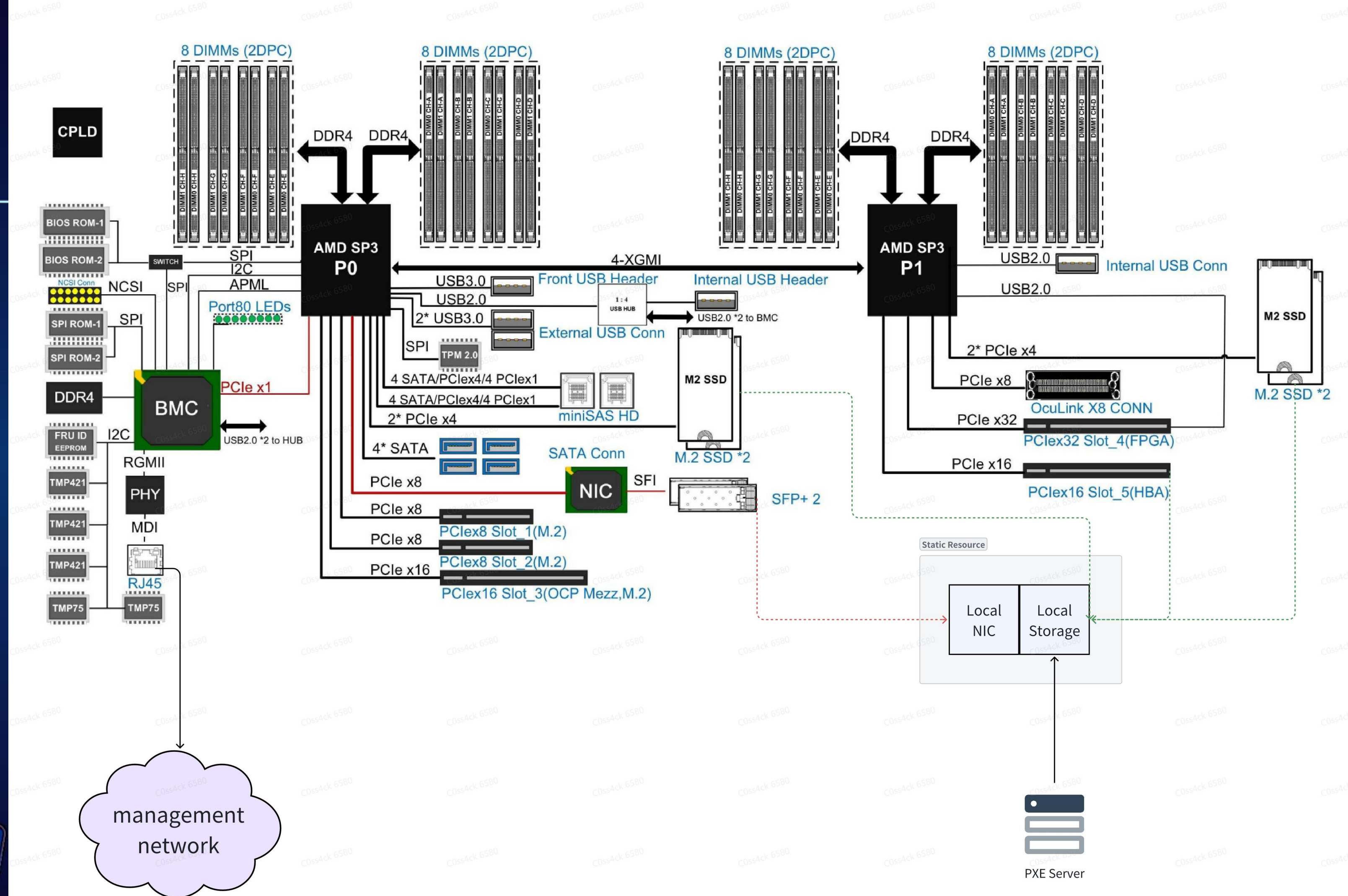
按照业务功能来看标准服务器的逻辑拓扑=>

- BMC和Host为并行关系
- BMC可以透过多个物理信道控制Host
- Host也可以复用这些物理信道访问BMC
- 这也是在云上引发诸多安全隐患的原因



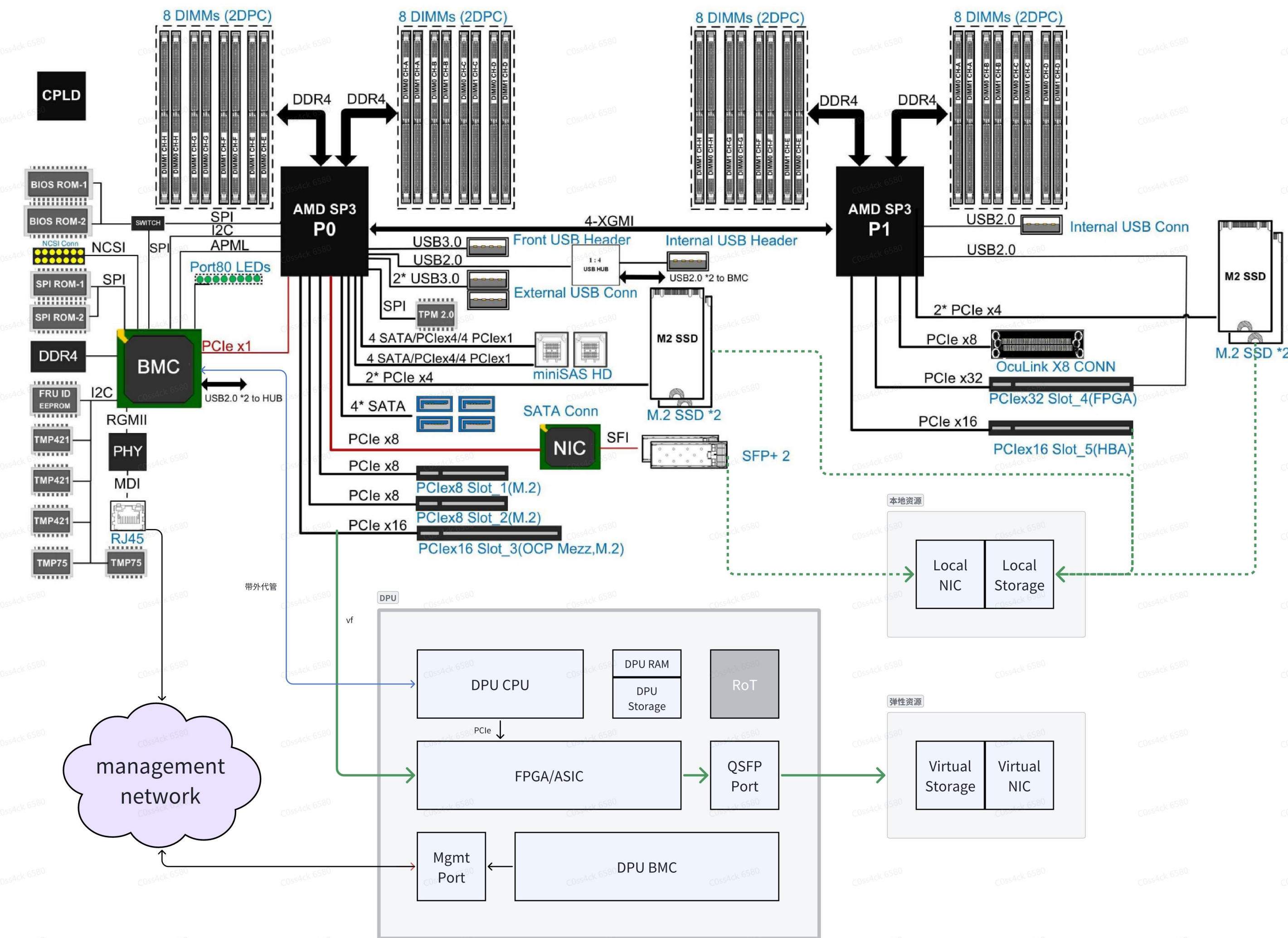
1.2. 经典裸金属

- 常包含在专有云、边缘云
- 机型老旧
- 租户运维，CSP维保
 - BMC带内功能无阉割
 - 依赖PXE装机
 - 租户自建管理网或CSP代建独立管理网
 - 退租后CSP做数据安全擦除



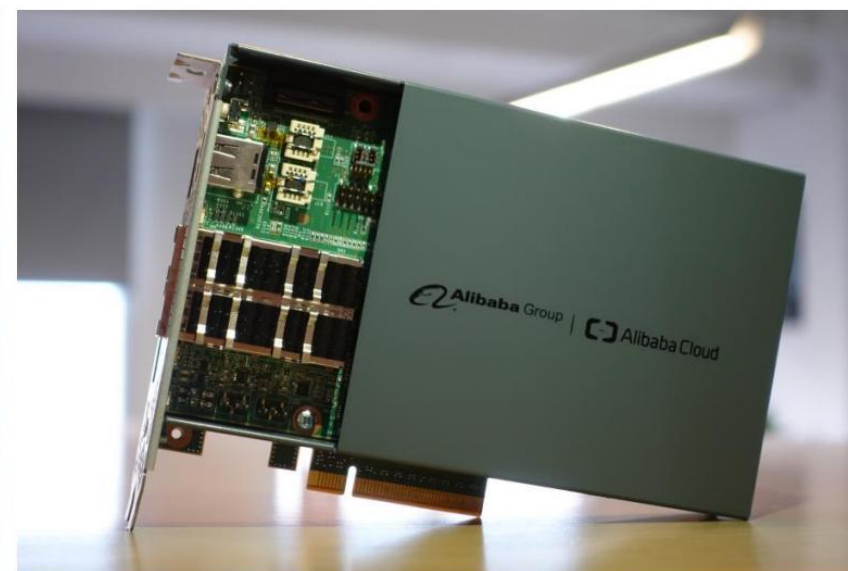
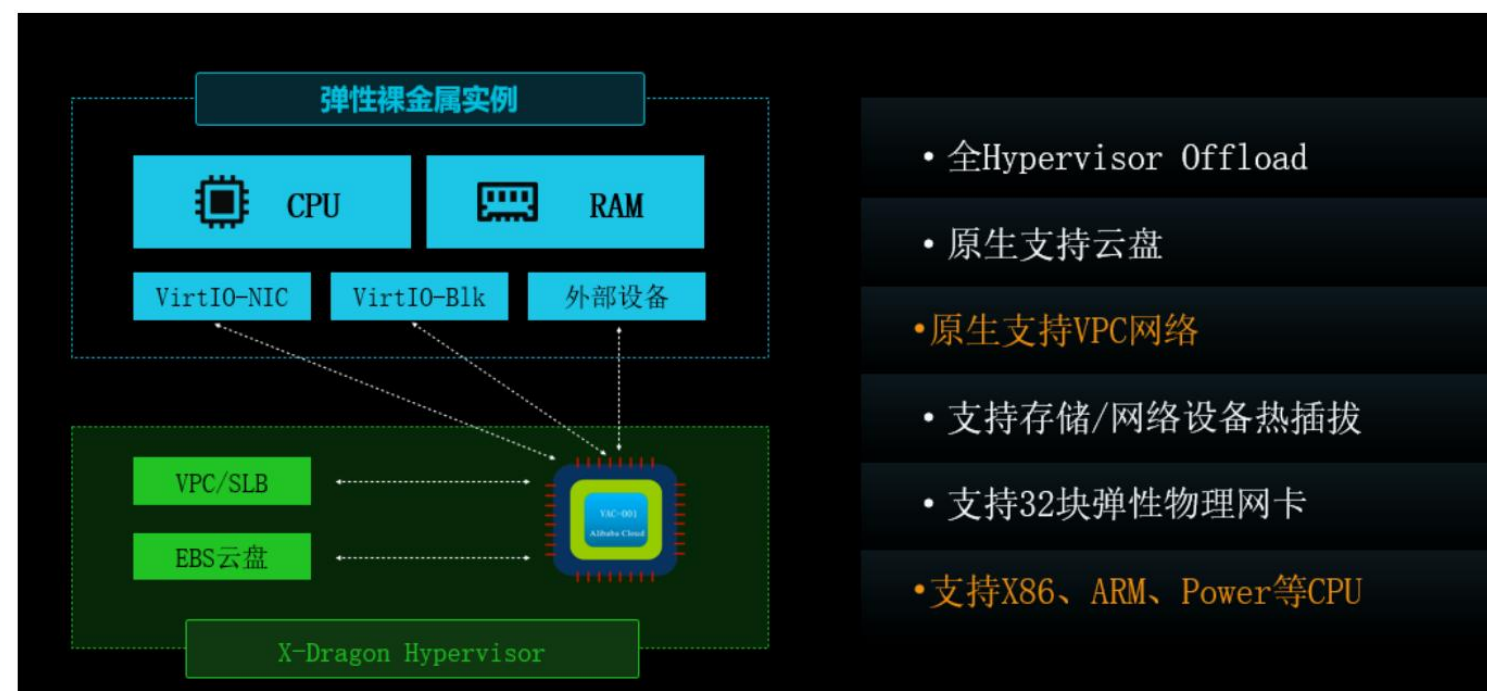
1.3. 弹性裸金属

- 常包含在公有云
- 机型相对新（毕竟DPU才火没几年）
- CSP运维+维保
 - BMC带内功能被阉割
 - 通过DPU(SmartNIC)供应弹性资源如存储
 - 租户仅能访问VPC
 - 退租后CSP做数据安全擦除



1.4. 弹性裸金属（DPU方案）的早期入场者——阿里云、AWS

X-Dragon：自研MOC卡

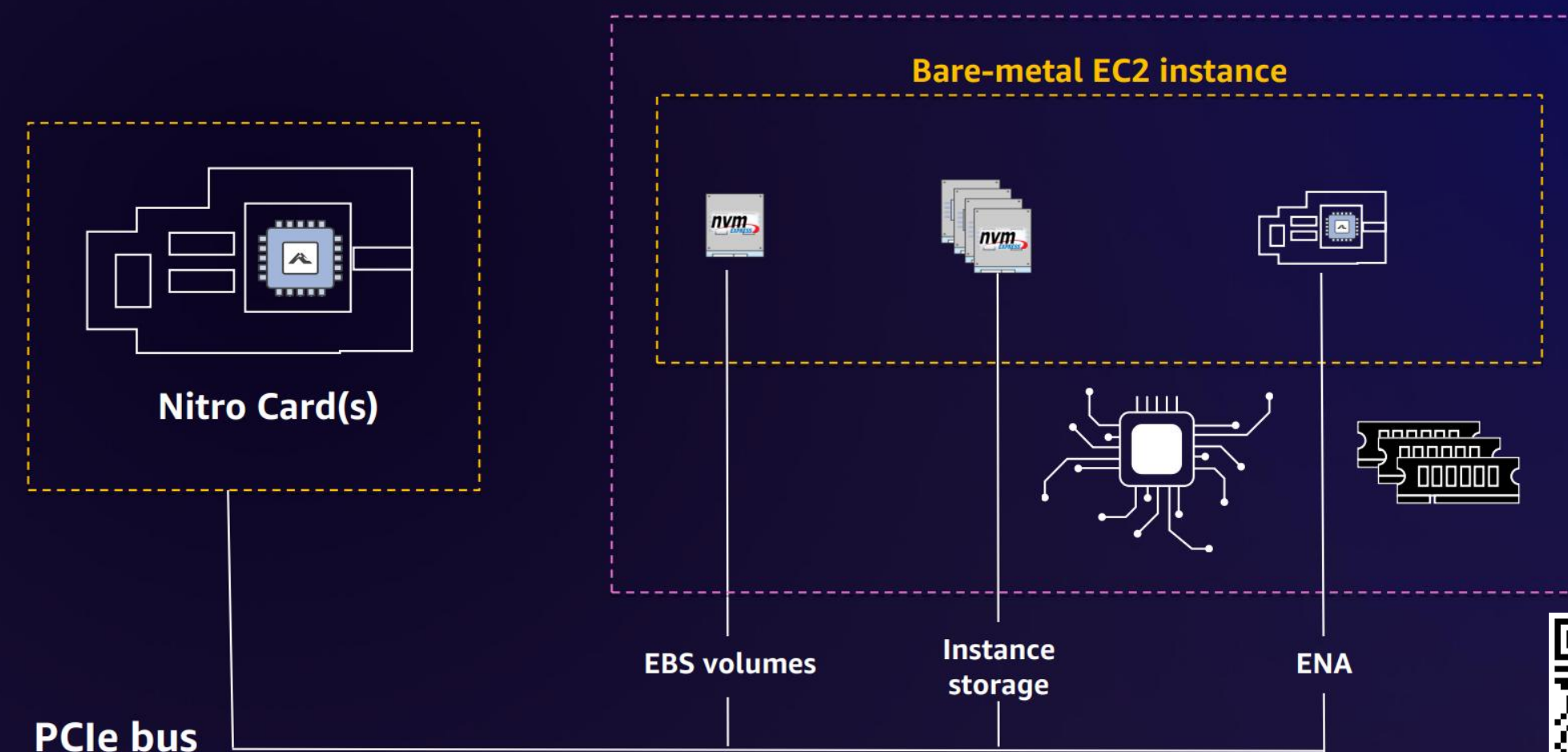


阿里云MoC卡（实物图）



MOC卡让物理机具备虚拟机一切体验

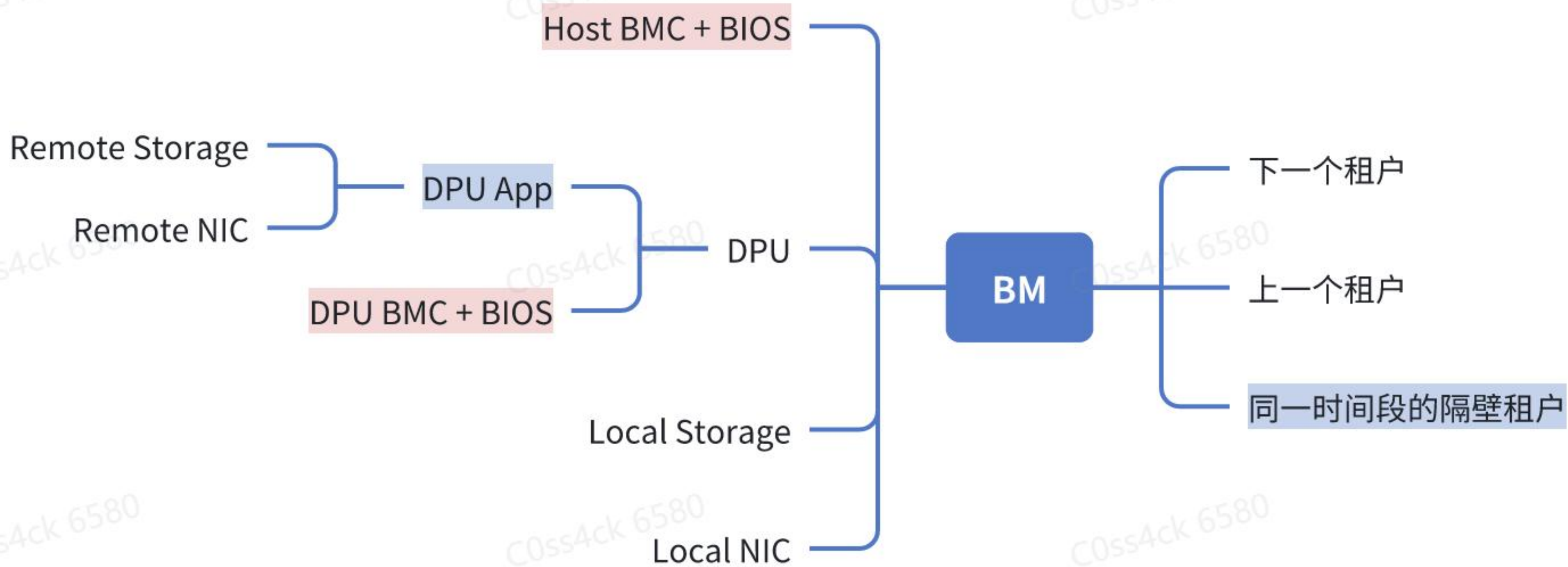
Nitro bare-metal architecture



© 2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.



2. 经典攻击面

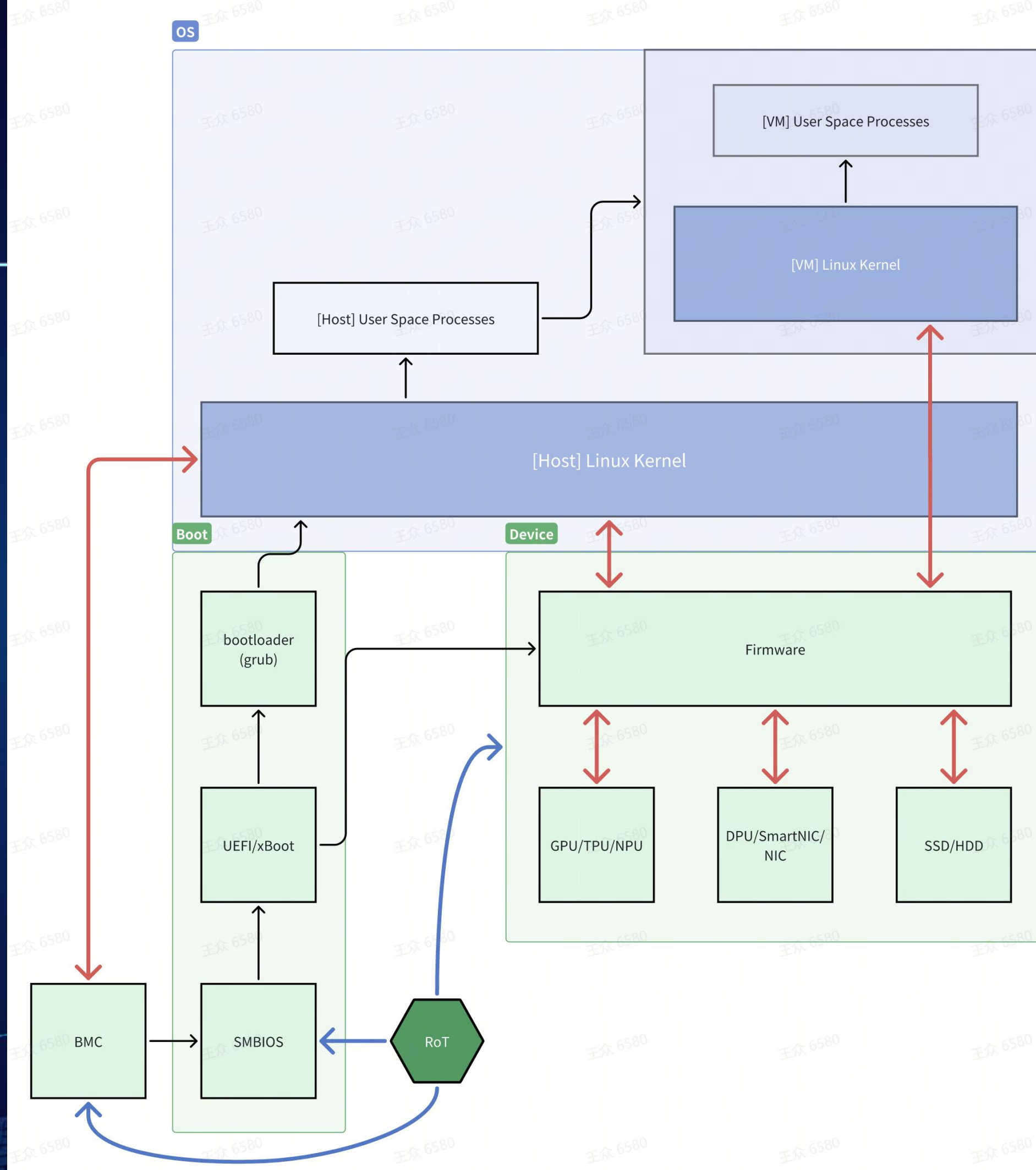


2.1. 固件完整性

- 针对固件完整性的攻击，常在整机/板卡(冷/热)重启后加载新固件时触发，所以我们需要了解
 - 服务器启动流程
 - 无板载RoT+安全启动时，完整性易受攻击的——
 - BMC
 - PCIe外设

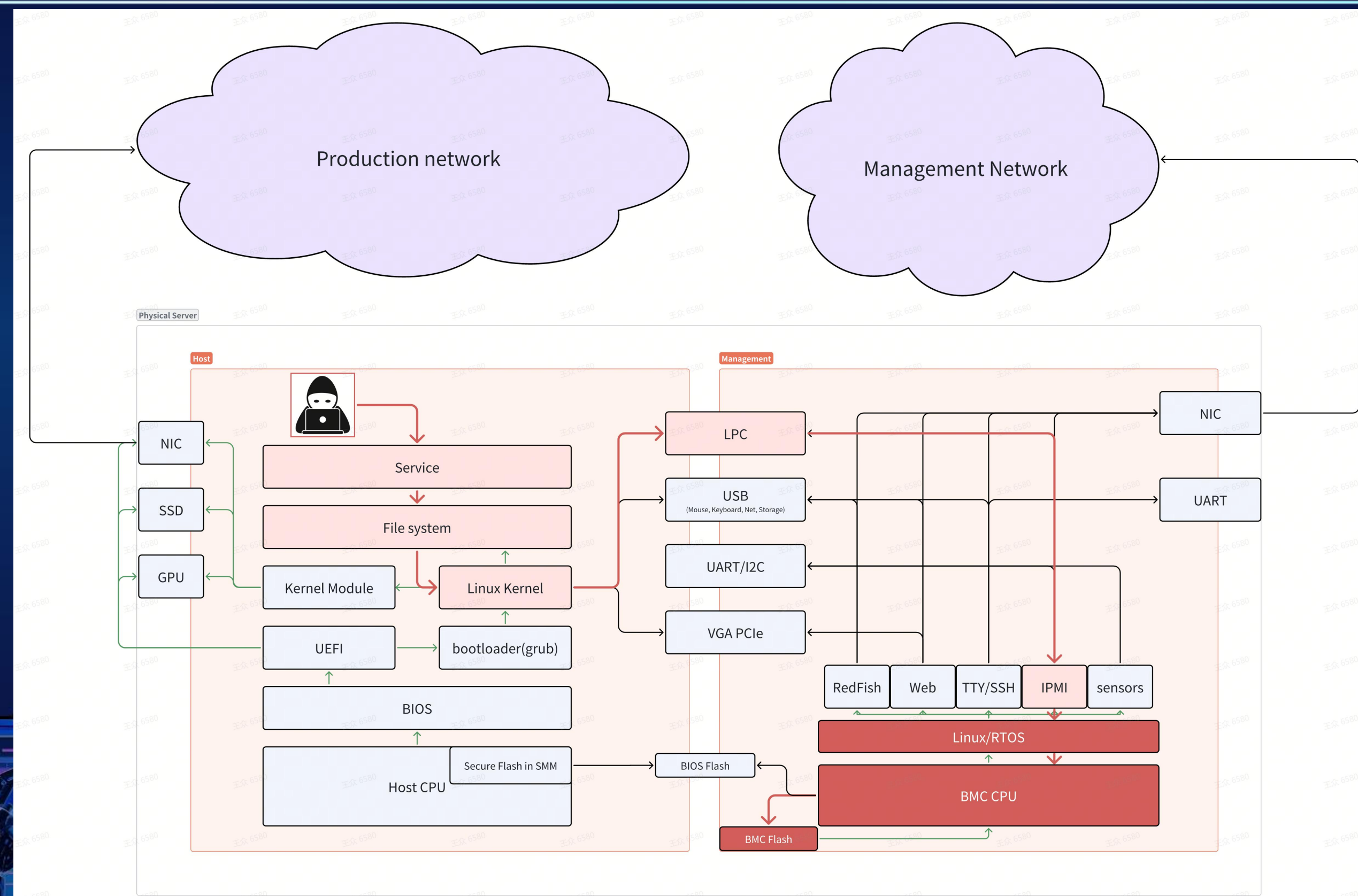
2.1.1. 服务器启动流程

- AC上电，BMC启动
- ==>BMC发起或运维按开机键
- ==>DC供电（主板和PCIe外设都上电）
- ==>UEFI POST（PEI => DXE => BDS => TSL => ...）
- ==>UEFI DXE阶段加载PCIe外设固件
- ==>UEFI TSL阶段运行bootloader（UEFI App）
- ==>bootloader拉起OS
- 然后大家都熟悉了，vmlinuz=>vmlinux=>...



2.1.2. 从BMC到bootkit playground

- 前提: 启用BMC固件升级验签,未启用BMC安全启动和主板安全启动
- Pantsdown/socflash/CVE-2019-6260+Yafu/CVE-2023-34335
- BMC的ipmi/redfish/webUI漏洞那么多,为什么只看这两?
 - 绕过了redfish的升级接口,直接读写BMC spi flash
 - 受影响服务器存量巨大,且难以修复
 - 表面漏洞,实际**后门**



2.1.2. 从BMC到bootkit playground

某野鸡云物理机

```
debug: Permissive
Debug UART port: UART5
xdma: Restricted
BMC: Disabled
VGA: Enabled
XDMA on VGA: Enabled
XDMA is constrained: Yes
p2a: Permissive
BMC: Disabled
VGA: Enabled
MMIO on VGA: Enabled
[0x00000000 - 0x0fffffff] Firmware: Writable
[0x10000000 - 0x1fffffff] SoC IO: Writable
[0x20000000 - 0x2fffffff] BMC Flash: Writable
[0x30000000 - 0x3fffffff] Host Flash: Writable
[0x40000000 - 0x5fffffff] Reserved: Writable
[0x60000000 - 0x7fffffff] LPC Host: Writable
[0x80000000 - 0xffffffff] DRAM: Writable
ilpc: Permissive
SuperIO address: 0x2e
```

```
# ipmitool raw 0x32 0x21 -v
Loading IANA PEN Registry...
Running Get VSO Capabilities my_addr 0x20, transit 0, target 0
Invalid completion code received: Invalid command
Discovered IPMB address 0x0
RAW REQ (channel=0x0 netfn=0x32 lun=0x0 cmd=0x21 data_len=0)
Unable to send RAW command (channel=0x0 netfn=0x32 lun=0x0 cmd=0x21 rsp=0xc7): Request data length invalid
```

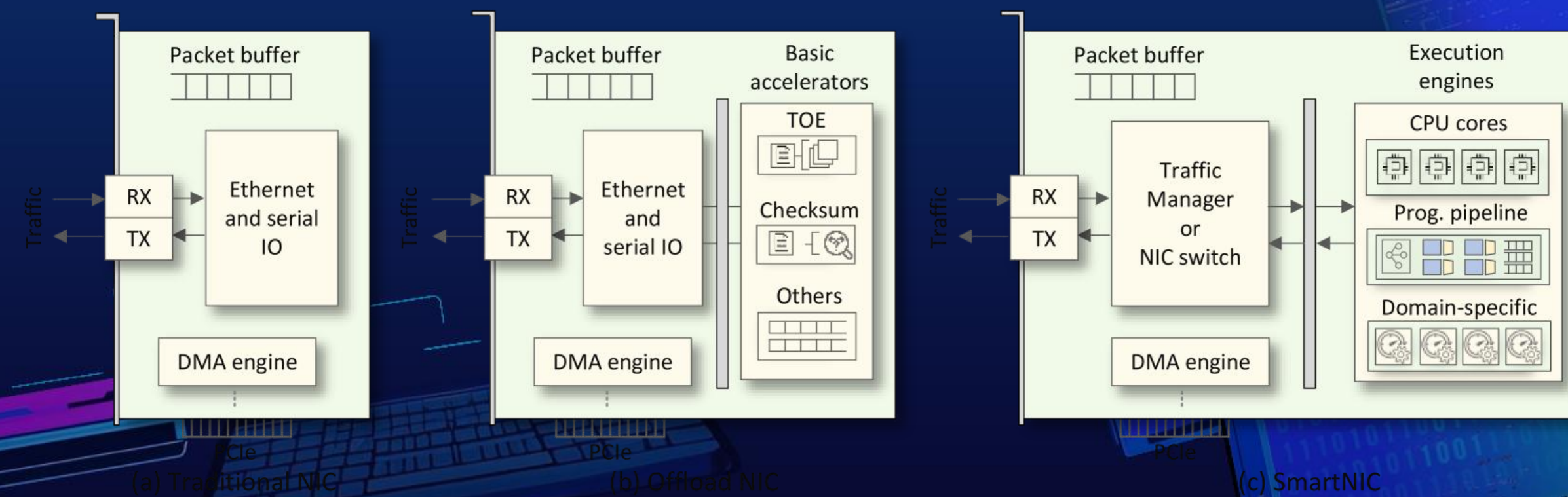
阿里云EBM

```
SuperIO: Disabled
VGA PCIe device: Enabled
MMIO on VGA device: Enabled
P2A write filter state:
0x00000000-0x0fffffff (Firmware): Read-only
0x10000000-0x1fffffff (SoC IO): Read-only
0x20000000-0x2fffffff (BMC Flash): Read-only
0x30000000-0x3fffffff (Host Flash): Read-only
0x40000000-0x5fffffff (Reserved): Read-only
0x60000000-0x7fffffff (LPC Host): Read-only
0x80000000-0xffffffff (DRAM): Read-only
X-DMA on VGA device: Enabled
BMC PCIe device: Disabled
X-DMA is unconstrained: No
Debug UART: Disabled
```

```
# ipmitool raw 0x32 0x21 -v
Running Get PICMG Properties my_addr 0x20, transit 0, target 0
Error response 0xc1 from Get PICMG Properties
Running Get VSO Capabilities my_addr 0x20, transit 0, target 0
Invalid completion code received: Invalid command
Discovered IPMB address 0x0
RAW REQ (channel=0x0 netfn=0x32 lun=0x0 cmd=0x21 data_len=0)
Unable to send RAW command (channel=0x0 netfn=0x32 lun=0x0 cmd=0x21 rsp=0xc1): Invalid command
```

2.1.3. 用老旧PCIe外设打穿Host

- 以华硕 AN1500 HBA为例
 - OXM厂商泄露固件刷写工具，操控MMIO控制SPI读写固件
 - 无板卡级的安全启动，固件加载前只验证CRC，无验签
 - 可直接修改OpROM，在UEFI DXE阶段投毒
- 以英伟达 CX3、CX4为例
 - 公开mstflint工具，操控MMIO控制SPI读写固件
 - 同样无板卡级的安全启动，同样只有CRC，上电后运行恶意固件
 - 同样可直接修改OpROM，也可以滥用DMA能力读写Host内存



2.2. CSP其他网段跳板

- 管理网
 - Host BMC
 - DPU BMC
 - 各种背板BMC(少数和管理网之间隔着上面俩BMC,但也有直连管理网的)
- 生产网
 - DPU
 - 各种功能的类DPU卡(比如AWS Nitro的VPC DPU和EBS DPU)

2.2.1. Host => BMC => 管理网 (以MegaRAC为例)

- Host getshell BMC
 - ipmi RCE: CVE-2023-34336
 - evil fw+reboot: 参考2.1.2刷恶意固件 + ipmitool mc reset cold
- BMC get shell BMC
 - Redfish后台RCE: CVE-2022-40259、CVE-2023-34334
 - +Redfish认证绕过: CVE-2023-34329、CVE-2024-54085
 - +无一机一密, 取证原BMC的ipmi/redfish账密: CVE-2023-25191
 - slpd RCE: CVE-2023-29552
 - Virtual Media RCE、Key Video Mouse RCE: CVE-2023-3729[3-7]

2.2.2. Host => DPU => 生产网 (以Bluefield为例)

- DPU对Host的访问控制
 - 错误部署模式 (Bluefield默认以DPU Mode运行, 允许Host通过rshim控制DPU、烧录固件等, 而裸金属下应当使用Zero-Trust/Restrict Mode禁止Host控制DPU)
- DPU App
 - spdk, 没人fuzz
 - dpdk, 仍然没人fuzz
 - 其他卸载功能 (Bluefield DOCA支持数据解压缩、AES-GCM的卸载), 还是没人fuzz



懂我的意思吧

2.3. 数据安全擦除

- 远古案例: Rackspace and VPS.net未擦除租户数据就轮转硬盘给下一个租户



- 近日案例: 腾讯云恢复号称“无法恢复的客户数据”



数码荔枝 @DIGITALYCHEE · Apr 28

今天一个软件开发者找我们下架软件，原因大致为：

- 一、他们把所有的代码 + 数据库都托管在腾讯云上。
- 二、腾讯云欠费 2 元后发通知，但开发者手机开了免干扰没注意；
- 三、约 7 天后，腾讯云将他们的数据都删除，且无法恢复；
- 四、开发者没做数据备份，现在连用户是谁都不知道了。

一个 10 万+用户的产品就此无了。



数码荔枝

@DIGITALYCHEE

最新进展：开发者给我们留言，说腾讯云团队已经为他解决了问题。

希望腾讯云团队未来加强在极端情况下对用户的强提醒。

当然，也希望每个开发者重视自己的数据安全。

3. 广告位: bmcwalk

- 写了个趁手的玩具
- 自动解析BMC固件
- 静态扫描漏洞



```
02:15:11 root@workstation ~ → bmcwalk-scan.py --path /opt/bmcwalk/examples/ASUS_PRO-WS-WRX80E-SAGE-SE-1.32.0.ima --rules CVE-2023-34335 CVE-2025-23016 --manufacturer asus --product wrx80e-sage-se --version 1.32.0
```

BMCWALK

```
2025-05-21 14:15:15.399 | INFO      | bmcwalk.extractor:part_extract_squashfs:87 - Found SQUASHFS @ 0x160000
2025-05-21 14:15:15.445 | INFO      | bmcwalk.extractor:save_to_img:84 - IMAGE of root has been saved to /tmp/91ba118c51a18f5d4b491a0e25430a58.img
Warning: run r2 with -e bin.cache=true to fix relocations in disassembly
2025-05-21 14:15:36.601 | SUCCESS   | bmcwalk.operator:scan_image_by_fw_path:61 - Hit CVE-2025-23016:CVE-2025-23016-vuln at /tmp/91ba118c51a18f5d4b491a0e25430a58-root-out-files/usr/local/lib/libfcgi.so.0.0.0
2025-05-21 14:16:00.971 | SUCCESS   | g:do:271 - found cosflash
2025-05-21 14:16:01.009 | SUCCESS   | bmcwalk.operator:scan_image_by_fw_path:61 - Hit CVE-2023-34335:CVE-2023-34335 at /tmp/91ba118c51a18f5d4b491a0e25430a58-root-out-files/usr/local/lib/libipmimgshndlr.so.6.205.0
2025-05-21 14:16:02.376 | SUCCESS   | bmcwalk.operator:scan_image_by_fw_path:61 - Hit CVE-2023-34335:CVE-2023-34335 at /tmp/91ba118c51a18f5d4b491a0e25430a58-root-out-files/usr/local/lib/libipmipdkcmds.so.6.1.0
```

3.1. 多种BMC固件解析

- 目前支持
 - MegaRAC (AMI=>各服务器供应商)
 - OpenBMC (Linux基金会)
 - 某国产厂商魔改版MegaRAC (固件丢了, 好像是浪潮某个系列)
- 计划支持
 - iDRAC (戴尔)
 - iLO (惠普)
 - iBMC (华为)
 - HDM (华三)
 - Bluefield OpenBMC (缺个密钥)



- “\$MODULE\$”为各分区开头（部分厂商会自定义分区结构体）
- +0x18为分区名， +0x24为文件系统的绝对偏移（部分版本为相对偏移）

014:FFE0	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	yyyyyyyyyyyyyyyyyy
014:FFF0	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	yyyyyyyyyyyyyyyyyy
015:0000	24	4D	4F	44	55	4C	45	24	01	08	40	00	00	00	77	01	\$MODULE\$..@...w.
015:0010	00	00	15	00	00	00	00	39	72	6F	6F	74	00	00	00	00	9root....
015:0020	0C	03	60	00	00	00	16	00	00	30	75	01	01	00	00	00	..`.....0u.....
015:0030	00	81	4F	6C	98	00	30	30	30	30	30	30	00	00	AA	55	..01~.000000..^u
015:0040	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	yyyyyyyyyyyyyyyyyy
015:0050	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	FF	yyyyyyyyyyyyyyyyyy

015:FFE0	FF FF FF FF	FF FF FF FF	FF FF FF FF	FF FF FF FF	FF FF FF FF	FF FF FF FF
015:FFF0	FF FF FF FF	FF FF FF FF	FF FF FF FF	FF FF FF FF	FF FF FF FF	FF FF FF FF
016:0000	68 73 71 73	66 14 00 00	96 CA FE 63	00 10 00 00	hsqsf...-Êpc....	
016:0010	D2 01 00 00	04 00 0C 00	C0 02 01 00	04 00 00 00	ò.....À.....	
016:0020	F2 17 9C FB	00 00 00 00	6B 26 75 01	00 00 00 00	ò.æû....k&u.....	
016:0030	63 26 75 01	00 00 00 00	FF FF FF FF	FF FF FF FF	c&u.....ÿÿÿÿÿÿÿÿ	
016:0040	0F 42 73 01	00 00 00 00	31 43 74 01	00 00 00 00	.Bs.....lCt.....	
016:0050	B9 08 75 01	00 00 00 00	2D 26 75 01	00 00 00 00	' .u.....&u.....	
016:0060	FD 37 7A 58	5A 00 00 01	69 22 DE 36	03 C0 BD 0A	y7zXZ...i"p6.À½.	
016:0070	80 20 21 01	00 00 00 00	9D F1 D2 2E	E0 0F FF 05	€ !.....ñÒ.à.ÿ.	
016:0080	35 5D 00 3F	91 45 84 68	3B DE DE A6	0F 23 F0 D4	5].?'E,,h;pP . #ðÖ	
016:0090	24 19 E7 A6	7E 36 A7 7C	ED 17 E1 3F	B3 72 63 AF	\$.ç!~6\$ í.á?³rc	
016:00A0	7E 50 86 4E	77 C3 6C D1	E7 C1 F6 05	F1 61 0D 13	~P†NwÃlÑçÁö.ña..	
016:00B0	6A ED 0B EC	51 9A 72 1B	98 38 3B E9	6D 9C 2D 60	jí.iQšr.~8;émœ-	

3.1.2. OpenBMC固件解析

• 标准的DTB结构

04F:6170	00 00 00 03	00 00 00 1B	00 00 00 00	46 6C 61 74	Flat
04F:6180	74 65 6E 65	64 20 44 65	76 69 63 65	20 54 72 65	tened Device Tre
04F:6190	65 20 62 6C	6F 62 00 00	00 00 00 03	00 00 F3 90	e blob.....ó.
04F:61A0	00 00 00 1B	D0 0D FE ED	00 00 F3 90	00 00 00 38	Đ.pí..ó....8
04F:61B0	00 00 EB F0	00 00 00 28	00 00 00 11	00 00 00 10	..ěď...(.....
04F:61C0	00 00 00 00	00 00 07 A0	00 00 EB B8	00 00 00 00	ě,....
04F:61D0	00 00 00 00	00 00 00 00	00 00 00 00	00 00 00 01	
04F:86D0	72 6F 66 73	40 61 30 30	30 30 30 00	00 00 00 03	rofs@a00000.....
04F:86E0	00 00 00 08	00 00 03 42	00 A0 00 00	02 50 00 00	B. ...P..
04F:86F0	00 00 00 03	00 00 00 05	00 00 04 0C	72 6F 66 73	rofs
09F:FFE0	FF FF FF FF	FF FF FF FF	FF FF FF FF	FF FF FF FF	yyyyyyyyyyyyyyyy
09F:FFF0	FF FF FF FF	FF FF FF FF	FF FF FF FF	FF FF FF FF	yyyyyyyyyyyyyyyy
0A0:0000	68 73 71 73	D1 0E 00 00	70 7F A2 5A	00 00 02 00	hsqsÑ...p.çZ....
0A0:0010	C6 00 00 00	04 00 11 00	C0 00 05 00	04 00 00 00	Æ.....À.....
0A0:0020	CB 19 9C 7C	00 00 00 00	34 A1 04 02	00 00 00 00	Ë.æ4i.....
0A0:0030	2C A1 04 02	00 00 00 00	FF FF FF FF	FF FF FF FF	,i.....yyyyyyyy

```
&fmc {
    status = "okay";
    flash@0 {
        status = "okay";
        compatible = "jedec,spi-nor";
        label = "bmc";
        spi-max-frequency = <50000000>;
        partitions {
            compatible = "fixed-partitions";
            #address-cells = <1>;
            #size-cells = <1>;

            u-boot@0 {
                // 896KB
                reg = <0x0 0xe0000>;
                label = "u-boot";
            };

            kernel@100000 {
                // 9MB
                reg = <0x100000 0x900000>;
                label = "kernel";
            };

            rofs@a00000 {
                // 55292KB (extends to end of 64MB SPI - 4KB)
                reg = <0xa00000 0x35FF000>;
                label = "rofs";
            };
        };
    };
};
```

3.2. 静态扫描BMC固件漏洞

- 目前支持
 - Semgrep匹配伪代码
 - 根据函数名、caller、callee、引用字符串做过滤
 - 多个semgrep pattern串联
 - 自定义idapy脚本
- 计划支持
 - ~~POC什么时候才能有OpenAPI~~

3.2.1. 匹配BMC伪代码

- 以最新的CVE-2025-23016为例

- Headless IDA位置: ...

- 适用类型: MegaRAC

- 扫描引擎: semgrep

- 扫描分区: rootfs

- 扫描路径: libfcgi.so....

- 扫描文件类型: 二进制

- 过滤caller: FCGX_Accept_r

Y CVE-2025-23016.yml X

```
1 idat: /opt/ida-pro-9.1/ida
2 name: CVE-2025-23016
3 type: ["MegaRAC"]
4 engine: semgrep
5 target: root
6 detail:
7   - name: CVE-2025-23016-vuln
8     path_pattern: \/\libfcgi\.\so[0-9\-\_\.\.]{0,1}
9     file_type: ["so", "elf"]
10    filter:
11      functions: []
12      callers: ["FCGX_Accept_r"]
13      callees: []
14      strings: []
15    lang: "c"
16    fix_func_types:
```

```
rules:
- id: CVE-2025-23016
  options:
    symbolic_propagation: true
  metadata:
    author: c0ss4ck9989@gmail.com
    references:
      - https://github.com/FastCGI-Archives/fcgi2/issues/67
    confidence: MEDIUM
  message: >-
    FastCGI fcgi2 (aka fcgi) 2.x through 2.4.4 has an integer overflow (and resultant heap-based buffer overflow)
  severity: ERROR
  languages:
    - c
    - cpp
  patterns:
    - pattern: |
        while( ... ) {
          ...
          $NAME_LEN = $GET_CHR(...);
          ...
          if ( ... ) {
            if ( $GET_STR(...) != 3 ) {
              ...
            }
            $NAME_LEN = ...;
          }
          ...
        }
    - pattern-not: |
        while( ... ) {
          ...
          $NAME_LEN = $GET_CHR(...);
          ...
          if ( ... ) {
            if ( $GET_STR(...) != 3 ) {
              ...
            }
            $NAME_LEN = ...;
            if (<... $NAME_LEN ...>) {
              ...
            }
            ...
          }
          ...
        }
    - focus-metavariable: $NAME_LEN
```

3.2.2. 自定义扫描脚本

- 以CVE-2023-34335为例
 - 需匹配CmdHndlr和NetfnTbl这两个字典中的数据（很显然semgrep干不来这活）
 - 根据非控制流信息判断是否存在漏洞时，可以单独开发idapython脚本

```
def check_cmd_handler_with_cmd_switch(self, display=False):
    netfn_cmd_map = {}
    for cmd_handler_item in self.cmd_handler:
        netfn = f"{int(cmd_handler_item.NetFn):02x}"
        if netfn not in netfn_cmd_map.keys():
            netfn_cmd_map[netfn] = {}
        for cmd_handler_map_item in cmd_handler_item.CmdHndlrMap:
            cmd = f"{int(cmd_handler_map_item.Cmd):02x}"
            if cmd not in netfn_cmd_map[netfn].keys():
                netfn_cmd_map[netfn][cmd] = {}
            netfn_cmd_map[netfn][cmd]["Enabled"] = "unknown"
            if isinstance(cmd_handler_map_item.CmdHndlr, func_t):
                cmd_handler_pointer = f"`{get_ea_name(cmd_handler_map_item.CmdHndlr.start_ea)}`"
            else:
                cmd_handler_pointer = f"@{int(cmd_handler_map_item.CmdHndlr):08x}"
            netfn_cmd_map[netfn][cmd]["CmdHndlr"] = cmd_handler_pointer
    for cmd_switch_item in self.cmd_switch:
        netfn = f"{cmd_switch_item.NetFn:02x}"
        if netfn not in netfn_cmd_map.keys():
            self.debug_log(f"not found {netfn} in `cmd_handler`")
            continue
        for net_fn_cmd in cmd_switch_item.NetFunction:
            cmd = f"{int(net_fn_cmd.CmdNum):02x}"
            if cmd not in netfn_cmd_map[netfn].keys():
                self.debug_log(f"not found {cmd} under {netfn}")
                continue
            netfn_cmd_map[netfn][cmd]["Enabled"] = "false" if net_fn_cmd.Status == NetFnCmdsItemStatus.DI
    if display:
        print(json.dumps(netfn_cmd_map, indent=4))
    return netfn_cmd_map
```

4. 一些思考

- 老牌云厂商、依托大厂成长的云厂商在裸金属服务器的安全架构已经相对成熟（毕竟都是阿里云和 A W S 出来的）
 - 有自研DPU，虽然DPU App是个新攻击面，但白帽子接触不到☹
 - 整机和外设普遍有RoT



THANKS!